

Description of Work (DOW) for: Cybersecurity Engineering Services (SMA5)

1.1 Objectives

The Contractor shall provide Cybersecurity Engineering Services that include designing, implementing, and maintaining enterprise security controls that enforce Zero Trust principles, including identity-centric access, least privilege enforcement, continuous monitoring, and threat detection across cloud, network, and endpoint environments. The Contractor will ensure that security technologies, systems, and services – including cloud platforms, identity services, endpoints, and security tooling – are properly configured, hardened, and continuously monitored in accordance with federal security standards and industry's best practices. The objective of this support is to strengthen the organization's overall security posture and improve detection and response capabilities.

1.2 Scope of Work

The Contractor personnel provided under this Description of Work shall provide engineering, operational, and advisory support to enhance, secure, and sustain CBO's enterprise cybersecurity environment. This effort supports the remediation of identified Incident Response (IR) findings, strengthens overall security posture, and ensures alignment with federal cybersecurity standards, including NIST SP 800-53 and NIST SP 800-207 (Zero Trust Architecture). The Contractor will assist in the design, implementation, and maintenance of enterprise security controls across cloud, network, endpoint, and identity environments, with a focus on enforcing Zero Trust principles, least privilege access, and continuous monitoring.

The scope of work includes, but is not limited to, the following activities:

- **Enterprise Security Operations:** Support the implementation, operation, and optimization of enterprise security platforms and services, ensuring protection, availability, and performance across cloud, on-premises, and hybrid environments in support of mission requirements.
- **Security Architecture & Compliance Support:** Assist in implementing and maintaining security controls aligned with NIST SP 800-53 and NIST SP 800-207 (Zero Trust Architecture), including participation in continuous monitoring, risk mitigation, and maintaining overall security posture.
- **Identity & Access Management (IAM):** Support the configuration and management of identity services, including authentication, authorization, role-based access controls, and multi-factor authentication, ensuring enforcement of least privilege and Zero Trust principles.
- **Threat Detection & Incident Response:** Monitor, analyze, and respond to security events and alerts using enterprise security tools (e.g., SIEM, EDR/XDR); support incident triage, containment, investigation, and remediation activities.
- **Security Monitoring & Operations Support:** Assist in maintaining continuous monitoring capabilities, including log collection, correlation, and analysis, to enhance visibility and support proactive threat detection and response.
- **Vulnerability Management & Remediation:** Support vulnerability scanning, assessment, and remediation efforts across systems and applications; coordinate patching and mitigation activities to ensure compliance and risk reduction.

- **Cloud & Application Security Support:** Assist in securing cloud platforms (e.g., AWS, Azure) and application environments, including configuration management, secure integrations, and enforcement of security best practices across development and operational workflows.
- **Change Management & Documentation:** Participate in change management processes, maintain accurate security documentation, and support the development and upkeep of security policies and standard operating procedures to ensure audit readiness and operational continuity.
- **Customer Service & Team Collaboration:** Serve as a technical resource for advanced service desk tickets and security-related issues, collaborating with network, cloud, and engineering teams to resolve complex challenges and improve overall security operations.

1.2.1 Specific requirements / Tasks

The Contractor shall perform the following tasks in support of the enterprise cybersecurity environment:

- Implement and maintain enterprise security controls aligned with NIST SP 800-53, including access control (AC), configuration management (CM), system and communications protection (SC), audit and accountability (AU), incident response (IR), and system and information integrity (SI) control families.
- Enforce Zero Trust Architecture principles in accordance with NIST SP 800-207, including continuous verification of users and devices, identity-centric security, and least privilege access across cloud, network, and endpoint environments.
- Design, implement, and maintain least-privilege access controls, including role-based access control (RBAC), privileged access management (PAM), and multi-factor authentication (MFA) across enterprise systems and applications.
- Configure and manage identity and access management (IAM) solutions, ensuring secure authentication, authorization, and integration with enterprise identity providers.
- Configure and maintain centralized logging, monitoring, and audit capabilities across systems, applications, and cloud platforms, ensuring integration with enterprise SIEM tools and compliance with log retention policies.
- Conduct continuous security monitoring, vulnerability assessments, and risk analysis across enterprise environments; identify security gaps and coordinate remediation in alignment with NIST Risk Management Framework (RMF) practices.
- Harden systems, applications, and cloud environments using secure configuration baselines and industry best practices, including disabling unnecessary services, enforcing encryption standards, and securing administrative access.
- Secure cloud and hybrid environments (e.g., AWS, Azure), including configuration of security services, identity controls, network protections, and workload security.
- Identify, manage, and remediate vulnerabilities across systems, applications, and infrastructure, including coordination of patch management and mitigation strategies.

- Support incident response activities by monitoring alerts, performing analysis, executing containment actions, and assisting with forensic data collection and reporting.
- Implement and maintain segmentation and access control strategies to limit lateral movement and protect sensitive data and high-value assets.
- Ensure all security changes follow formal change management processes, including documentation and security impact analysis, in compliance with NIST configuration management requirements.
- Develop, implement, and maintain cybersecurity Standard Operating Procedures (SOPs); review and update periodically to reflect evolving threats, technologies, and policies.
- Document and maintain system configurations, security baselines, and asset inventories; ensure documentation is current and supports audit readiness.
- Perform root cause analysis (RCA) for security incidents and control failures; document findings and implement corrective and preventive actions.
- Support automated patch management and security update processes across systems and platforms in accordance with organizational policies.
- Support continuous, real-time security monitoring (24/7 operations) through integration with security tools such as SIEM, EDR/XDR, and cloud-native security platforms.
- Maintain accurate and up-to-date documentation of security configurations, processes, and procedures to ensure compliance, audit readiness, and operational continuity.
- Collaborate with network, cloud, and application teams to resolve security issues, support security integration, and enhance overall enterprise security posture.